

CYBERINFINITI LTD
Security Operations Centre(SOC)

Security Operations & Incident Response Report

Malware Analysis. Threat Detection · Incident Investigation · Vulnerability Management

Report ID	SOC-TIV-2026-INT-001
Report Date	April 2026
Version	1.1 (compiled)
Classification	Confidential / Internal Use
Prepared by	CyberInfiniti SOC Analyst Team
Distribution	CyBlack Team · SOC Team · Executive Management

Analyst Team

John Ofulue · Halimat Omorinsola Adepegba · Favour Obisike · Ikenna Emerole · Blessing Ibe · Ayodimeji Omole · Divine Ezewele · Andrew Moses · Odunayo Balogun

Table of Contents

1. Executive Summary	3
2. Scope & Methodology	4
3. Incident Overview & Attack Flow	5
4. Incident Timeline & MITRE ATT&CK® Mapping	6
5. Threat Intelligence Context & Alert Correlation	8
6. Response Actions (Containment · Eradication · Recovery)	9
7. Indicators of Compromise (IoCs)	10
8. Vulnerability Management	11
9. Further Actions	12
10. Lessons Learned	13
11. Recommendations & Improvement Roadmap	14
12. Conclusion	15
Appendix A — Evidence Gallery	16
Appendix B — Sprint Attendance & Team Contributions	18
Appendix C — Mini-Report Summaries	19
Appendix D — Incident Response Playbook (NIST SP 800-61)	21
Appendix E — Custom Sentinel Detection Rules	23

1. Executive Summary

During the April 2026 Security Operations sprint, CyberInfiniti Ltd's SOC team investigated and responded to three interconnected security incidents and completed two parallel vulnerability assessments. This summary describes what occurred, the impact, the response, and the next steps. Technical detail is provided in the body of the report.

What Happened

Three thematically related incidents were identified: **(i)** a coordinated phishing campaign targeting five employees with credential-harvesting links and an executable payload; **(ii)** the brute-force compromise of an internal user account, leading to confirmed download of payroll records and an internal vulnerability assessment; and **(iii)** the discovery of a sophisticated malware infection (AsyncRAT and Raccoon Stealer) on three production servers and three senior-staff workstations. In parallel, the team completed planned reviews of the mobile-device fleet and Microsoft Patch Tuesday advisories, both of which surfaced material unaddressed risk.

Impact

The phishing wave reached at least five employees; one email contained a working malicious link and another delivered an executable, both posing real risk of compromise. The account takeover resulted in confirmed exfiltration of sensitive employee data and an internal security assessment, creating potential regulatory exposure under data-protection law. The malware infection affected six systems and was actively communicating with attacker infrastructure with capability for credential theft, remote control and lateral spread; no ransomware activity was observed. The vulnerability reviews identified 250 mobile devices carrying actively exploited Android CVEs and several critical, unpatched Microsoft vulnerabilities, including a CVSS 9.8 pre-authentication remote code execution flaw.

What the Team Did

The SOC team executed a structured containment, eradication and recovery response across all three incidents. Malicious emails were blocked at the gateway; the compromised account was reset, isolated and forced through MFA; attacker IPs were firewalled; infected hosts were quarantined via EDR; malware artefacts and persistence mechanisms were removed; and a credential reset was initiated for affected accounts. Action plans with prioritised SLAs were issued for the mobile and Microsoft patching workstreams.

Next Steps

Recovery work continues. Re-imaging of affected systems is in progress; a data-exposure and regulatory-notification assessment is underway; enterprise-wide MFA enforcement, expanded detection rules in Microsoft Sentinel, MDM procurement, and updated incident response playbooks are being delivered. A formal post-incident review is recommended within 14 days of incident closure.

Sprint at a Glance

Workstream	Severity	Status
Phishing Email Campaign (×5)	HIGH	Completed
Account Compromise — Erwin Smith	HIGH	Contained
Malware Outbreak (AsyncRAT + Raccoon Stealer)	CRITICAL	Remediation in progress
Mobile Device Vulnerability Assessment	HIGH	Action plan issued

Microsoft Patch Tuesday — July 2025	CRITICAL	Deployment in progress
-------------------------------------	----------	------------------------

2. Scope & Methodology

2.1 Scope of Work

This report covers all activities completed during the Security Operations sprint:

- Investigation of five user-reported phishing emails.
- Analysis of suspicious sign-in patterns from authentication logs.
- Full malware analysis in a controlled detonation environment.
- Vulnerability assessments of the mobile device fleet and Microsoft estate.
- Authoring of standardised incident-response playbooks.
- Engineering of custom detection alerts in Microsoft Sentinel.
- Documentation of meetings, evidence chain, and team contributions.

2.2 Methodology

Investigations followed a structured, repeatable SOC workflow: (1) data collection from Azure AD, Carbon Black EDR, email artefacts, and CVE advisories; (2) analysis using the MITRE ATT&CK® framework with IoC extraction across VirusTotal, URLScan, ANY.RUN, Hybrid Analysis, Splunk, and Microsoft Sentinel; (3) evidence-based documentation with screenshots, logs, and minutes; and (4) peer-reviewed, collaborative decision-making for response actions.

2.3 Lab Environment

Test identities were provisioned in Azure AD to simulate a realistic enterprise tenant and support each investigation workstream:

User	Role
Shina Kagawa	Customer Service Adviser
Kendrick Lawal	Head of Marketing & Customer Experience
Erwin Smith	Financial Analyst (compromised account)
Nike Fury	Operations Manager
Michelle Jackson	Lead Software Engineer
Marshall D Teach	Chief Information Security Officer
Lily Tunechy	Graphics Designer

Microsoft Azure

Search resources, services, and docs (G+)

Home > Cyberinfiniti | Microsoft Entra ID > Users

Cyberinfiniti | Microsoft Entra ID

Users

All users Bulk operations Columns Refresh Review Diagnose Download users

+ New user User type Any Add filters Got feedback?

Search users

All users

☐	Name	User name	ID	User type
☐	Shina Kagawa	shina.kagawa@cyberinfiniti.onmicrosoft.com		Member
☐	Kendrick Lawal	kendrick.lawal@cyberinfiniti.onmicrosoft.com		Member
☐	Erwin Smith	erwin.smith@cyberinfiniti.onmicrosoft.com		Member
☐	Nike Fury	nike.fury@cyberinfiniti.onmicrosoft.com		Member
☐	Michelle Jackson	michelle.jackson@cyberinfiniti.onmicrosoft.com		Member
☐	Marshall D Teach	marshall.teach@cyberinfiniti.onmicrosoft.com		Member
☐	Lily Tunechy	lily.tunechy@cyberinfiniti.onmicrosoft.com		Member

Fig. 1 – Azure AD dashboard showing the provisioned lab

3. Incident Overview & Attack Flow

3.1 Incident Summary

Incident / Task	Description	Classification	Severity	Status
Phishing Email Campaign (×5)	Five inbound emails analysed for malicious URLs and payloads.	Phishing / Social Engineering	HIGH	Completed
Account Compromise — Erwin Smith	Brute-force takeover; confirmed data exfiltration from SharePoint.	Account Compromise	HIGH	Contained
Malware Outbreak — VVIP & Servers	AsyncRAT + Raccoon Stealer via malicious ZIP; C2 established.	Malware Outbreak	CRITICAL	Remediation in progress
Mobile Device Vulnerability Mgmt	3 actively exploited Android CVEs across ~250 devices; no MDM.	Vulnerability Mgmt	HIGH	Action plan issued
Microsoft Patch Tuesday — Jul 2025	132 CVEs incl. 6 actively exploited; critical patches pending.	Patch Mgmt	CRITICAL	Deployment in progress

3.2 Common Pattern Across Incidents

All three incidents exploited a user-facing delivery channel (email or web), all involved credential theft or unauthorised access, and all progressed toward data exfiltration. The matrix below summarises the parallel attack flows.

Stage	Phishing Campaign	Account Compromise	Malware Outbreak
Initial Access	Malicious email delivered to 5 employees	Brute-force logins from 79.124.60.6 (Bulgaria)	Employee browses malicious domain
Execution / Interaction	User interacts with URL or attachment	Successful authentication to SharePoint (31 Jul 13:11)	ZIP downloaded and extracted via WinRAR
Action on Objective	Credential harvesting / malware delivery attempted	Sensitive files accessed: payroll + vulnerability report	AsyncRAT + Raccoon Stealer executed from %TEMP%
Detection / Containment	Gateway blocks; user notified	Account isolated; data exfiltration confirmed	C2 established; production servers infected; isolated

4. Incident Timeline & MITRE ATT&CK® Mapping

4.1 Chronological Event Timeline

The timeline below covers the three incidents across 25–31 July 2023. Vulnerability-management activities ran in parallel across the sprint and are noted at the end.

Date / Time	Incident	Event	Source / IP	Outcome
25–29 Jul 2023	Account Compromise	Normal baseline activity from UK IP	143.58.226.102 (UK)	Legitimate
29 Jul ~15:22–16:27	Phishing	Five malicious/suspicious emails delivered	Multiple Gmail IPs	Under analysis
30 Jul 10:45	Account Compromise	Failed login — Microsoft Exchange	79.124.60.6 (BG)	FAILED
31 Jul 08:20	Account Compromise	Failed login — Microsoft Outlook	79.124.60.6 (BG)	FAILED
31 Jul 09:50	Account Compromise	Successful login — Microsoft Online	150.158.77.170 (CN)	SUCCESS
31 Jul 10:20	Account Compromise	File access: vulnerability_report_June2023.docx	79.124.60.6 (BG)	DATA ACCESS
31 Jul 11:30	Account Compromise	Failed login — Azure CLI	124.120.140.202 (TH)	FAILED
31 Jul 13:11	Account Compromise	Successful login — SharePoint	79.124.60.6 (BG)	SUCCESS
31 Jul 17:10	Account Compromise	File download: updated_payroll.xlsx	79.124.60.6 (BG)	EXFILTRATION
Sprint period	Malware Outbreak	AsyncRAT + Raccoon Stealer delivered to VVIP host	vmi1159541.taboserver.net	CRITICAL
Sprint period	Malware Outbreak	C2 established to 128.24.231.64/65; svchost injection	128.24.231.64 / .65	C2 ACTIVE
Sprint period	Malware Outbreak	Lateral spread to ERP-PROD-002, DATA-PROD-001/002	Internal network	SPREADING
Sprint period	Vulnerability Mgmt	250 Android devices identified with unpatched critical CVEs	MDM audit	Action plan
Sprint period	Vulnerability Mgmt	MS Patch Tuesday Jul 2023: 132 CVEs incl. 6 actively exploited	Vendor advisory	Deployment in progress

4.2 MITRE ATT&CK® Framework Mapping

The matrix below maps observed adversary techniques to the MITRE ATT&CK® Enterprise framework across all three incidents. Where evidence was insufficient to confirm a technique, this is explicitly noted as a HYPOTHESIS.

Tactic	ID	Technique	Incident	Evidence / Notes
Initial Access	T1566.001	Spearphishing Attachment	Phishing	Emails with .exe payload and malicious Google Drive links delivered.
Initial Access	T1566.002	Spearphishing Link	Phishing	URLs to credential-harvesting sites (wtools.io, contaboserver.net).
Initial Access	T1110	Brute Force	Account Compromise	Multiple failed logins from 79.124.60.6 followed by success — credential stuffing.
Initial Access	T1204.002	User Execution: Malicious File	Malware	VVIP user executed ZIP containing AsyncRAT and Raccoon Stealer.
Execution	T1059	Command & Scripting Interpreter	Malware	Execution via WinRAR.exe from %TEMP% — Living-off-the-Land.
Persistence	T1547.001	Registry Run Keys / Startup Folder	Malware	Confirmed: HKCU\...\CurrentVersion\Run modified.
Persistence	T1053	Scheduled Task/Job	Malware	HYPOTHESIS — scheduled task creation suspected; not confirmed in sandbox window.
Persistence	T1078	Valid Accounts	Account Compromise	Stolen credentials used for ongoing SharePoint access.
Defense Evasion	T1036	Masquerading	Malware	Injected into svchost.exe and MoUsoCoreWorker.exe.
Defense Evasion	T1055	Process Injection	Malware	Confirmed: code injected into svchost.exe (PIDs 1684 / 6816).
Defense Evasion	T1497	Virtualisation / Sandbox Evasion	Malware	Anti-VM checks; obfuscated .NET to impede analysis.
Defense Evasion	T1074	Data Staged	Malware	Data staged in %TEMP% prior to exfiltration.
Credential Access	T1555	Credentials from Password Stores	Malware	Raccoon Stealer harvested browser-stored credentials.

Discovery	T1083	File and Directory Discovery	Account Compromise	Attacker browsed SharePoint to identify sensitive files.
Lateral Movement	T1021	Remote Services	Malware	HYPOTHESIS — spread to ERP-PROD-002 / DATA-PROD-001 likely via SMB or RDP.
Command & Control	T1071.001	Application Layer Protocol: Web	Malware	C2 over HTTPS to 128.24.231.64/65 mimicking Microsoft endpoints.
Command & Control	T1102	Web Service (Trusted Domain Abuse)	Malware	Abuse of login.live.com / settings-win.data.microsoft.com for tunnelling.
Exfiltration	T1041	Exfiltration over C2 Channel	Account Compromise	updated_payroll.xlsx and vulnerability_report_June2023.docx exfiltrated.

5. Threat Intelligence Context & Alert Correlation

5.1 Known Threat Actors & Tooling

The malware identified during the sprint matches publicly tracked tooling used by financially motivated, commodity threat clusters:

Tool / TTP	Attribution / Context
AsyncRAT	Open-source .NET Remote Access Trojan widely abused by mid-tier threat actors. Commonly delivered via phishing and used as an initial-access foothold for follow-on infostealers.
Raccoon Stealer (MuiUnattend.exe)	Malware-as-a-Service infostealer marketed on Russian-language criminal forums; targets browser credentials, crypto wallets, and session cookies.
Brute-force from Bulgaria (79.124.60.6)	IP belongs to an ASN repeatedly observed in commodity credential-stuffing campaigns; consistent with broad opportunistic targeting rather than a named APT.
NJRat-linked infrastructure (wtools.io)	Domain previously associated with NJRat operator infrastructure in open-source threat feeds, suggesting reuse by the same broader cluster.

Was this a previously identified risk? Yes. The team's prior threat-intelligence reporting had flagged commodity infostealer activity and credential-stuffing pressure against UK-based professional services as an elevated risk theme. The sprint's incidents are consistent with that risk picture rather than indicating a novel or targeted APT operation.

5.2 Relationship Between Alerts and Incidents

Although classified as separate incidents, the alerts share material overlap that points to a common opportunistic adversary mode of operation:

- Common entry vector: all three incidents originated through user-facing channels (email or web).
- Shared infrastructure pattern: malicious domains and IPs across the phishing and malware incidents resolve to low-cost VPS providers (Contabo, Linode), a pattern typical of commodity malware distribution.
- Convergent objective: every incident progressed toward credential theft or document exfiltration.
- Trust abuse: both the malware and the account-compromise leveraged legitimate Microsoft services (SharePoint, login.live.com, settings-win.data.microsoft.com) to blend in.
- Detection lag: in each case, alerts fired only after the action-on-objective stage, indicating a need for earlier-stage behavioural detections (covered in §11).

6. Response Actions

6.1 Containment

Phishing Campaign

- Email-gateway blocks for all malicious sender addresses and domains (wtools.io, contaboserver.net, theannoyingsite.com).
- Web-proxy blocks for malicious root domains and IPs (209.145.51.44, 188.166.15.204).
- Affected recipients notified and instructed not to interact with the emails.
- Malicious URLs and file hashes submitted to threat-intelligence platforms.

Account Compromise

- Immediate password reset on the compromised account.
- All active Microsoft 365 sessions forcibly terminated.
- Three malicious IPs blocked at the firewall: 79.124.60.6 (BG), 150.158.77.170 (CN), 124.120.140.202 (TH).
- MFA enforced on the affected account; Conditional Access policies tightened on SharePoint.

Malware Outbreak

- All six affected systems (ERP-PROD-002, DATA-PROD-001/002, Laptop-01324, -22123, -31214) disconnected and VLAN-isolated.
- Firewall rules deployed to block C2 IPs 128.24.231.64 and 128.24.231.65.
- Carbon Black EDR used to quarantine endpoints and halt binary execution.
- DNS sinkholing configured for identified C2 domains; web proxy updated with the malicious-URL blocklist.

6.2 Eradication

- Malicious processes (PIDs 1684 and 6816) terminated via Carbon Black on all affected systems.
- All malicious ZIP and EXE files removed from AppData\Local\Temp directories.
- Unauthorised registry modifications in HKCU\...\CurrentVersion\Run reverted.
- Full AV scan executed across the affected segment with updated definitions.
- Memory forensics capture initiated to identify in-memory-only components.
- Phishing artefacts removed from all affected mailboxes.

6.3 Recovery

- Enterprise-wide credential reset, prioritising VVIP, admin, and finance accounts.
- MFA enforcement extended to all critical-system accounts.
- Systems where persistence removal could not be verified are scheduled for full re-imaging from known-clean backups.
- 30-day enhanced monitoring across SIEM and EDR for affected systems and accounts.
- Four custom Microsoft Sentinel detection rules deployed (see Appendix E).
- Microsoft Patch Tuesday deployment under way; mobile-device update campaign launched with mandatory deadline.

7. Indicators of Compromise (IoCs)

Deploy the indicators below across all defensive platforms — SIEM, EDR, firewall, web proxy, and DNS filtering.

7.1 Network Indicators

Type	Indicator	Description	Confidence
IP	79.124.60.6	Primary attacker — brute-force and exfiltration (Bulgaria)	HIGH
IP	150.158.77.170	Phishing-flagged IP — successful auth observed (CN / Tencent)	MEDIUM
IP	124.120.140.202	Failed Azure CLI login (Thailand)	LOW
IP	128.24.231.64	Primary C2 (AsyncRAT / Raccoon Stealer)	HIGH
IP	128.24.231.65	Secondary C2 / Microsoft infrastructure spoofing	HIGH
IP	209.145.51.44	Hosts malicious payload and fake login portal	HIGH
IP	188.166.15.204	Hosts credential-harvesting infrastructure (wtools.io)	HIGH
Domain	wtools.io	Code-review lure / credential harvesting (NJRat-linked)	HIGH
Domain	contaboserver.net	Hosts payload.exe — malware delivery	HIGH
Domain	theannoyingsite.com	Social-engineering lure with malicious behaviours	HIGH
Domain	login.live.com	Legitimate domain abused for HTTP POST credential exfiltration	HIGH
Domain	settings-win.data.microsoft.com	Legitimate domain abused for TLS data tunnelling	HIGH

7.2 File Indicators

Type	Value	Description
MD5	e8186d5f86cba061f0b6913a952cc60e	AsyncRAT payload (mini_installer)
MD5	f30ac924dc003a7f7ddb676a1c9c0779	Raccoon Stealer (MuiUnattend.exe)
SHA-256	317e0a76962ba5435726b570ff84ac25374b65fb8001fdbeeab50aad1c0806e8	AsyncRAT payload
SHA-256	b773ca84f8a93ac8477e377178499e5f4bf65cf3fdf228c3c4a594fc19edd647	Raccoon Stealer
File	updated_payroll.xlsx	Payroll data confirmed exfiltrated from SharePoint
File	vulnerability_report_June2023.docx	Internal vulnerability report accessed by attacker

7.3 Host-Based Indicators

Category	Indicator
Registry Key	HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run (modified)
Registry Key	HKCU\SOFTWARE\WinRAR\ArcHistory (extraction of malicious archive)
File Path	C:\Users*\AppData\Local\Temp*.exe
File Path	C:\Users*\AppData\Local\Temp*.zip
Process	svchost.exe — verify parent process legitimacy (injection confirmed)
Process	MoUsoCoreWorker.exe — masquerading / service abuse

8. Vulnerability Management

8.1 Mobile Device Vulnerability Assessment

Three actively exploited Android vulnerabilities were identified across the device fleet, with no MDM solution in place to enforce or monitor compliance.

Device Fleet Risk Profile

Device Category	Count	Proportion	Risk
Devices up to date	250	50%	LOW
Devices outdated by ~1 year	200	40%	HIGH
Devices outdated by ~2 years	50	10%	CRITICAL
Total fleet	500	100%	—

Critical CVEs Identified

CVE	Component	Severity	Impact	Status
CVE-2021-29256	Arm Mali GPU Kernel Driver	HIGH	Use-After-Free; privilege escalation to root, no creds required	Actively exploited
CVE-2023-26083	Arm Mali GPU Kernel Driver	HIGH	Kernel memory disclosure; ASLR bypass enabling chained exploits	Actively exploited
CVE-2023-2136	Skia / Google Chrome	HIGH	Integer overflow; sandbox escape and RCE via crafted webpage	Actively exploited

Recommended Remediation

- Immediate: mandatory update notice to all staff with a 14-day compliance deadline.
- Immediate: segment outdated devices onto a restricted VLAN until patched.
- Short-term: deploy an MDM (recommended Microsoft Intune) for compliance enforcement.
- Long-term: formal mobile-device update policy with SLAs (critical ≤7 days; standard ≤30 days).
- Long-term: retire devices >3 years old that no longer receive vendor security updates.

8.2 Microsoft Patch Tuesday — July 2025

The July 2025 release addressed 132 CVEs, including 6 under active exploitation. The vulnerabilities of highest relevance to CyberInfiniti Ltd are summarised below.

CVE	CVSS	Component	Description	Priority
CVE-2025-47981	9.8	Windows SPNEGO	Pre-auth heap buffer overflow; RCE over network, no creds or interaction.	CRITICAL — ≤24 hrs
CVE-2025-53770	9.3	SharePoint Server	Deserialisation flaw; on-prem SharePoint RCE — directly relevant given recent	CRITICAL — ≤24 hrs

			SharePoint exfiltration.	
CVE-2025-49695	7.3	Microsoft Office	Local code execution via malicious document.	HIGH — 48–72 hrs
CVE-2025-47178	7.0	Configuration Manager	SQL injection enabling adjacent-network RCE across all managed endpoints.	HIGH — 48–72 hrs
CVE-2025-49719	6.5	SQL Server	Improper input validation; information disclosure on SOC tooling.	MEDIUM — ≤7 days

Note: CVE-2025-53770 (SharePoint) is of particular concern given that this sprint's account compromise involved exfiltration via SharePoint. Any unpatched SharePoint instance represents compounding risk.

9. Further Actions

9.1 Immediate (24–48 Hours)

- Apply CVE-2025-47981 (SPNEGO) and CVE-2025-53770 (SharePoint) across all affected systems.
- Complete enterprise-wide credential reset, prioritising VVIP, admin and finance accounts.
- Enforce MFA on all accounts (not just the compromised one).
- Complete re-imaging of the six confirmed infected systems.
- Conduct a Data Protection impact assessment to determine GDPR / DPA notification obligations.
- Notify HR and Legal regarding exposure of employee payroll data.

9.2 Short-Term (Within 1 Week)

- Complete deployment of the four custom Sentinel detection rules.
- Apply remaining MS Patch Tuesday updates (CVE-2025-49695, -47178, -49719).
- Audit all user accounts for lateral movement beyond the confirmed scope.
- Launch the mobile-device update campaign with mandatory compliance deadline.
- Submit MDM procurement for approval; begin vendor evaluation.
- Conduct a 30-day pre/post account audit on Erwin Smith's identity.
- Implement geo-based login alerting and impossible-travel rules in Splunk.

9.3 Medium-Term (Within 1 Month)

- Implement Conditional Access policies restricting authentication from high-risk geographies.
- Deploy application allow-listing to prevent execution of unsigned binaries from %TEMP% and %APPDATA%.
- Procure and deploy MDM across the full mobile device fleet.
- Conduct a formal post-incident review with all stakeholders.
- Update all incident response playbooks to incorporate sprint lessons.
- Launch a security-awareness programme focused on phishing and credential hygiene.
- Subscribe to commercial threat-intelligence feeds; integrate with Sentinel and Defender.

10. Lessons Learned

This section reflects on the response process itself — what worked, what did not, and where process or capability gaps were identified. The focus is on improving the response capability, not solely the technical controls.

10.1 Process Gaps Identified

Multi-Factor Authentication not universally enforced

The account compromise was made possible by absence of MFA on the affected identity. The attacker required only a guessable password; MFA would have blocked the brute-force flow regardless of password strength.

No Mobile Device Management in place

With 250 Android devices carrying actively exploited CVEs, the team had no centralised visibility, no automated patch push, and only manual self-reporting for compliance.

Patch management behind schedule

A CVSS 9.8 pre-auth RCE was pending deployment. A CVSS 9.0+ vulnerability should not remain unpatched beyond 24–48 hours in an organisation handling sensitive data.

Inadequate SharePoint access controls

A single compromised account was able to access both payroll and an internal vulnerability report. Sensitivity labels and RBAC should have constrained the blast radius.

Reactive rather than proactive detection

Both the brute-force and the malware infection were identified retrospectively. Behaviour-based alerting (foreign-IP logins, failed→success progressions, anomalous outbound traffic) was missing.

10.2 Response Challenges

Coordination and communication

Some delays occurred coordinating actions between the SOC, IT Infrastructure, and management. A pre-defined escalation path and rehearsed comms protocol — now captured in the playbooks (Appendix D) — should be exercised regularly.

Lack of pre-existing playbooks for specific scenarios

No pre-existing playbooks existed for credential-based account takeover or infostealer infections. Steps were determined during the incident, increasing response time. The playbooks developed in this sprint close this gap.

Evidence collection and chain of custody

Memory forensics were correctly identified before re-imaging, but a formal evidence-handling procedure suitable for legal proceedings was not in place. This should be incorporated into all IR processes.

10.3 What Worked Well

- Strong technical analysis: malware correctly classified, events accurately mapped to MITRE ATT&CK, IoC lists complete and high-confidence.
- Disciplined containment → eradication → recovery sequence prevented further malware spread.
- Custom Sentinel detection rules engineered in-sprint, converting reactive findings into proactive future detections.
- Effective parallel execution across three live incidents and two vulnerability assessments.
- Professional, prompt communication with affected users and management.

11. Recommendations & Improvement Roadmap

Recommendations are grouped into technical, logical (procedural) and administrative controls, followed by a prioritised improvement roadmap.

11.1 Technical Controls

Identity & Access

- Enforce MFA organisation-wide, no exceptions; prioritise privileged, finance and executive accounts.
- Implement Conditional Access to block or step-up authentication from high-risk geographies.
- Deploy impossible-travel detection in Splunk and Sentinel.
- Apply RBAC and Microsoft Information Protection sensitivity labels to sensitive SharePoint content.
- Quarterly access-review cycle, with immediate review for accounts involved in incidents.

Endpoint Security

- Application allow-listing to prevent execution of unsigned binaries from %TEMP% and %APPDATA%.
- Carbon Black EDR coverage on 100% of endpoints with automated agent-health checks.
- Microsoft Intune MDM with automated patch-compliance enforcement for the mobile fleet.
- Prohibit corporate access from personal devices that fail the security baseline.

Network Security

- Micro-segmentation for critical server infrastructure (ERP, production data stores).
- Dedicated higher-trust segment for VVIP workstations with enhanced monitoring.
- Egress filtering and alerting on large or unusual outbound transfers.
- Integrate IoC lists (§7) into firewall, web proxy, DNS filtering, and SIEM.

Detection & Monitoring

- Activate and tune the four custom Sentinel analytics rules from this sprint (Appendix E).
- Integrate dynamic threat-intelligence feeds into Sentinel and Defender.
- Expand Splunk logging for SharePoint file access/download events with bulk-download alerting.
- Build SOAR playbooks (Azure Logic Apps) to automate endpoint isolation and session revocation on Sentinel alerts.

11.2 Logical (Procedural) Controls

- Patch SLAs: Critical (CVSS 9.0+) ≤24 hrs · High ≤72 hrs · Medium next maintenance window.
- Formal emergency-change process so critical patches can deploy without bypassing controls.
- Monthly vulnerability-review cycle aligned to Patch Tuesday and other vendor advisories.
- Mandatory CISO sign-off before reconnecting any compromised system to production.
- Formal data-classification policy with mandatory training for all staff.

11.3 Administrative Controls

- Mandatory phishing-awareness programme with quarterly refreshers and simulated phishing.
- Clear incident-escalation matrix with severity-based notification SLAs (per Appendix D).
- Formal post-incident review within 14 days of closure with documented owners.
- Quarterly playbook review cycle and after-action update following any major incident.
- Notify affected employees per GDPR / DPA 2018 obligations; engage the DPO to assess regulatory reporting.
- Purple-team exercise within the next quarter, simulating phishing → credential theft → exfiltration to validate detection improvements.

11.4 Detection & Response Improvement Roadmap

Improvement	Priority	Owner	Target
Enterprise-wide MFA enforcement	CRITICAL	IT Admin / CISO	Immediate
SharePoint sensitivity labels & RBAC	HIGH	IT Admin / Compliance	≤1 week
Custom Sentinel rules — activation & tuning	HIGH	SOC Team	≤1 week
MDM procurement & deployment	HIGH	IT Infrastructure	≤1 month
SOAR playbook development (Azure Logic Apps)	HIGH	SOC Team	≤1 month
Phishing-awareness training launch	HIGH	HR / SOC Team	≤1 month
Geo-fencing & impossible-travel detection	MEDIUM	SOC / Security Eng.	≤2 weeks
Threat-intelligence feed integration	MEDIUM	SOC Team	≤1 month
Purple-team exercise	MEDIUM	SOC Lead / CISO	≤3 months
Quarterly playbook-review cycle	MEDIUM	SOC Lead	Ongoing

12. Conclusion

This sprint represents a meaningful test of CyberInfiniti Ltd's security operations capability. Across a compressed timeframe, the SOC team investigated three high-severity incidents, completed two vulnerability assessments, engineered custom detections, and delivered a suite of incident response playbooks while running active containment and remediation.

The incidents are not isolated events. They reflect the current threat landscape facing organisations of this profile and demonstrate that a determined adversary can achieve meaningful damage — in this case, confirmed exfiltration of payroll and internal vulnerability data — even before detection occurs.

Several foundational controls (MFA, MDM, structured patch management, proactive detection) were absent or insufficiently implemented at the time of the incidents. Addressing these gaps is not optional. The exfiltrated data creates real-world consequences: regulatory exposure, potential harm to affected employees, and risk that the attacker's possession of the vulnerability report enables further targeted attacks.

The recommendations in this report are prioritised and actionable. The most impactful near-term measures — enforcing MFA, completing system re-imaging, patching critical vulnerabilities, and activating the custom Sentinel detection rules — can be implemented immediately. The medium- and longer-term investments in MDM, SOAR automation, threat-intelligence integration, and staff training will compound the organisation's defensive capability over time.

Despite the gaps surfaced, this sprint has materially improved CyberInfiniti Ltd's security posture. The custom playbooks, detection rules, IoC lists, and documented lessons learned form a lasting foundation for a more resilient, proactive, and process-driven security operations function. A formal post-incident review is recommended within 14 days of incident closure to formally close all action items and capture residual lessons.

Appendix A — Evidence Gallery

Selected evidence captured during the investigations is presented below in compact form. Full sandbox reports, raw screenshots and detonation logs are retained in the SOC case file.

A.1 Email Threat Investigation

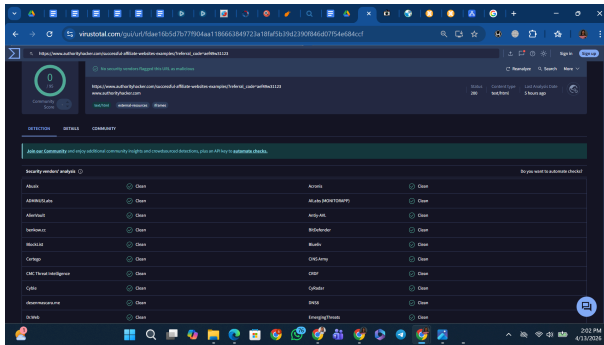


Fig. A1 — VirusTotal scan (URL reputation)

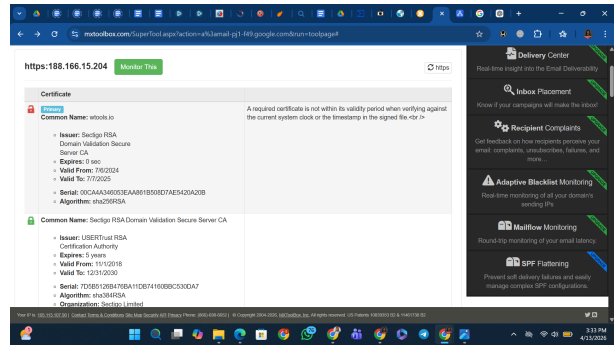


Fig. A2 — URL2PNG render of suspicious page



Fig. A3 — MX Toolbox email deliverability report

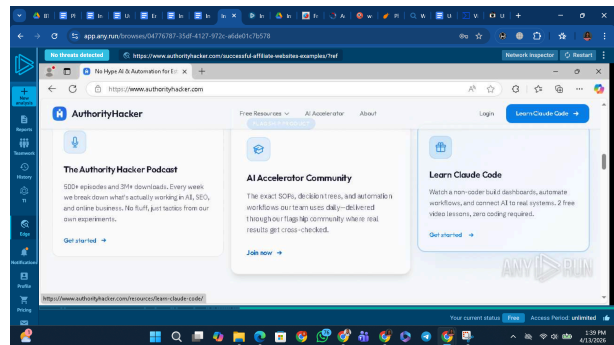


Fig. A4 — Hybrid Analysis sandbox verdict

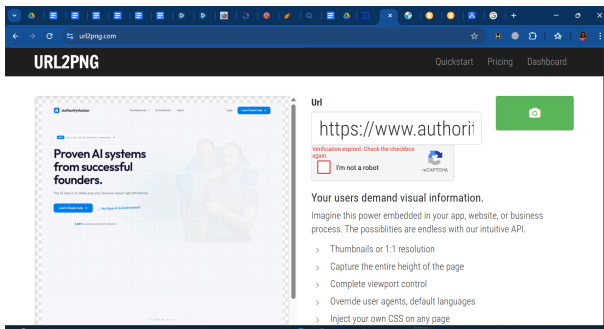


Fig. A5 — ANY.RUN browser sandbox network inspector

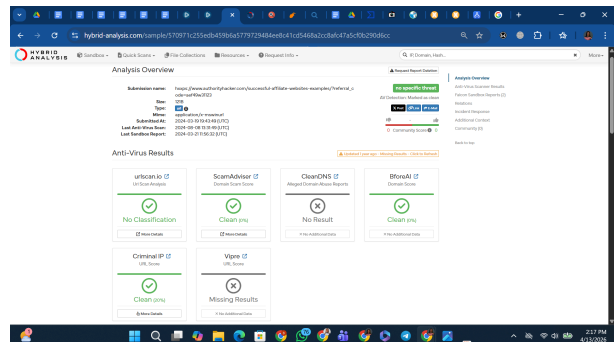


Fig. A6 — Reverse DNS lookup

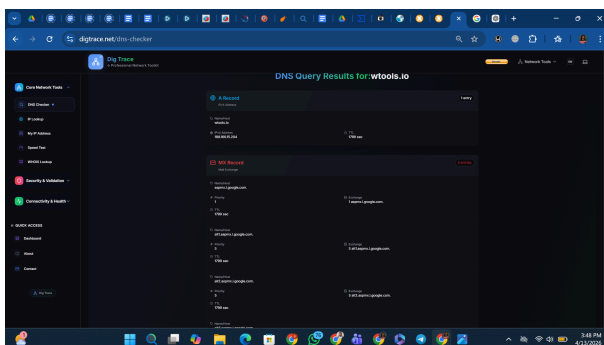


Fig. A7 — DigTrace DNS A-record lookup

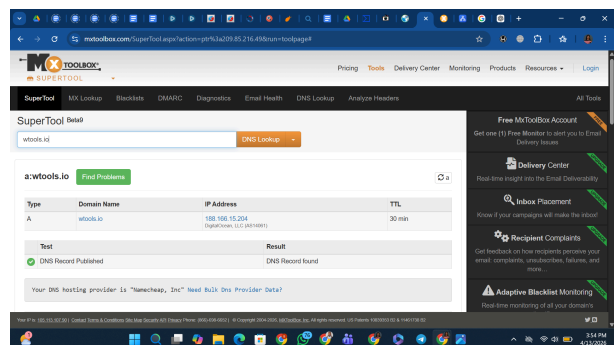


Fig. A8 — WHOIS lookup (theannoyingsite.com)

A.2 Suspicious Login Investigation

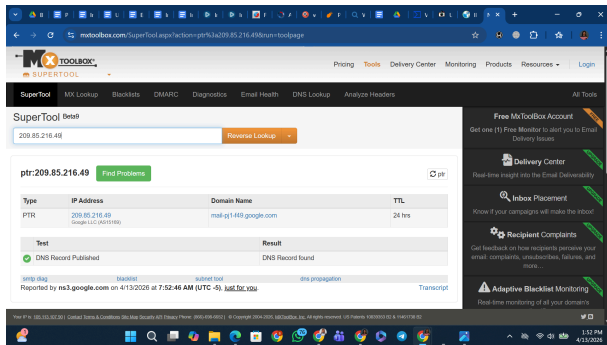


Fig. A9 — Authentication log — failed/success progression

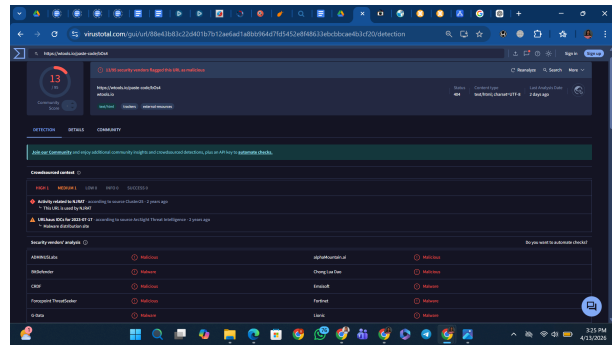


Fig. A10 — VirusTotal IP reputation 79.124.60.6

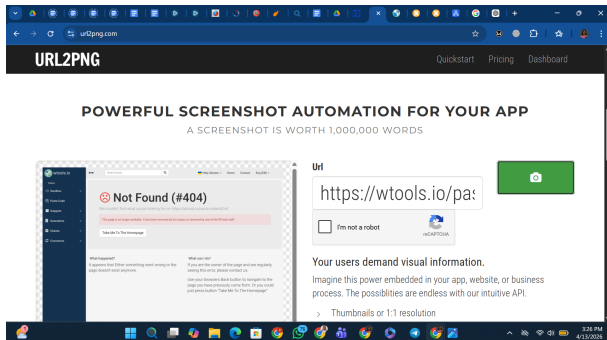


Fig. A11 — VirusTotal IP reputation 150.158.77.170

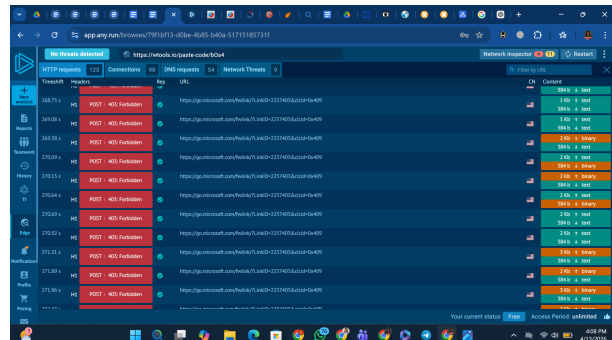


Fig. A12 — VirusTotal IP reputation 124.120.140.202

A.3 Malware Analysis

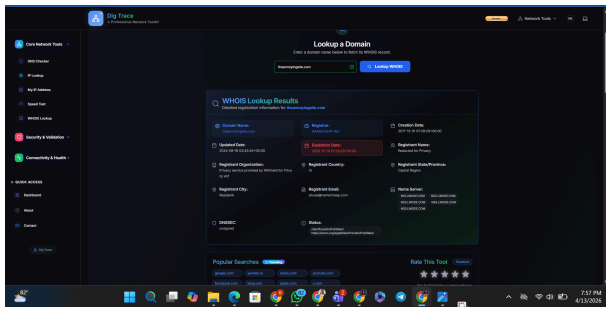


Fig. A13 — Static analysis: AsyncRAT (mini_installer)

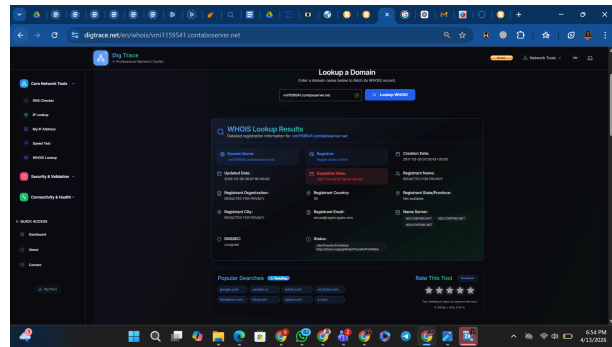


Fig. A14 — Static analysis: Raccoon Stealer (MuiUnattend.exe)

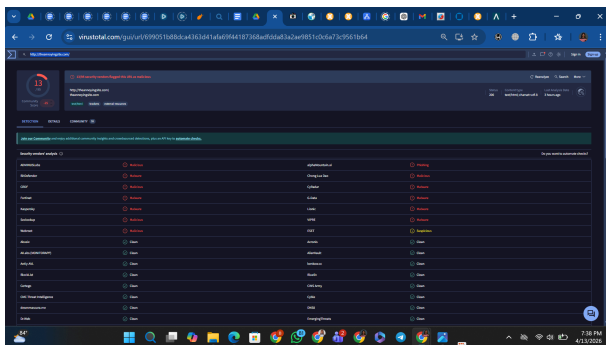


Fig. A15 — Process tree: WinRAR execution chain from %Temp%

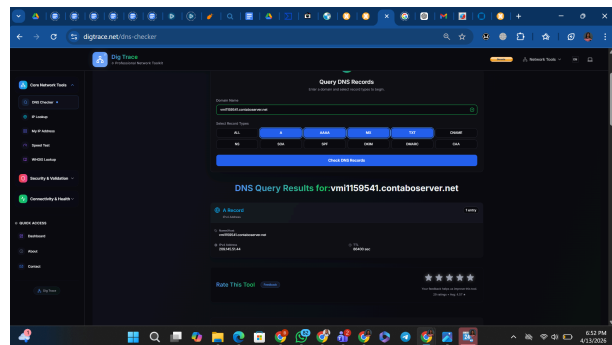


Fig. A16 — Automated detection verdict — Threat Score 100/100

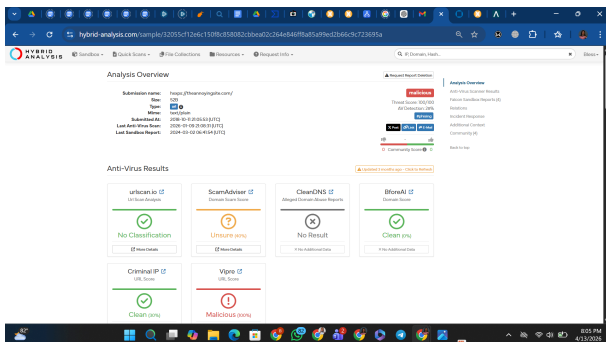


Fig. A17 — C2 traffic to 128.24.231.64 / .65

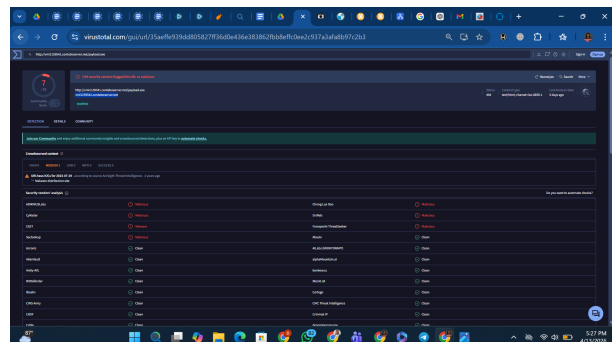


Fig. A18 — Process injection into svchost.exe

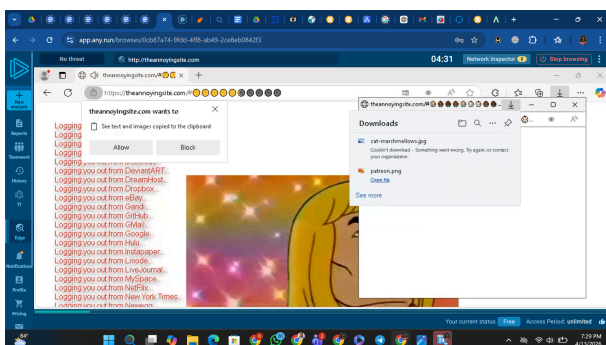


Fig. A19 — Registry persistence — HKCU...Run

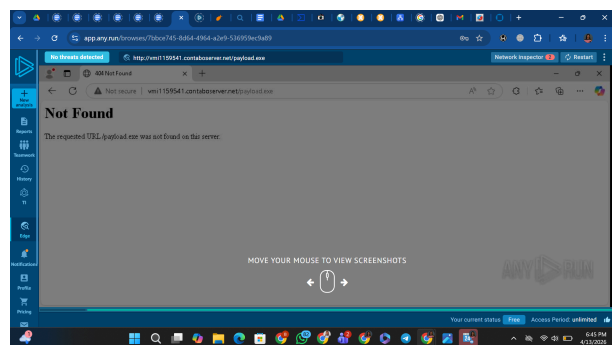


Fig. A20 — WinRAR ArchHistory: malicious archive extraction

Appendix B — Sprint Attendance & Team Contributions

B.1 Sprint Timeline & Meetings

Date	Time	Attendance
08/04/2026	20:10	Full team (9/9)
10/04/2026	20:10	Full team (9/9)
13/04/2026	20:10	Full team (9/9)
14/04/2026	—	Partial (working session)
17/04/2026	20:10	Full team (9/9)
18/04/2026	20:10	Full team (9/9)
20/04/2026	20:10	Full team (9/9)

Team roster: John Ofulue, Halimat Omorinsola Adepegba, Favour Obisike, Ikenna Emerole, Blessing Ibe, Ayodimeji Omole, Divine Ezewele, Andrew Moses, Odunayo Balogun.

B.2 Team Contributions

Team Member	Area of Contribution
John Ofulue	Lead coordination, task allocation, suspicious sign-in investigation, meeting facilitation.
Halimat Omorinsola Adepegba	Microsoft Patch Tuesday vulnerability management; report compilation; meetings.
Favour Obisike	Custom Sentinel alert engineering; meetings.
Ikenna Emerole	Sprint presentation; final-report modification; meetings.
Blessing Ibe	Email threat investigation; report writing and compilation; meetings.
Ayodimeji Omole	Presentation slide design; meetings.
Divine Ezewele	Mobile device vulnerability management; meetings.
Andrew Moses	Malware analysis (AsyncRAT, Raccoon Stealer); meetings.
Odunayo Balogun	Sprint presentation; meetings.

Appendix C — Mini-Report Summaries

Each workstream produced a standalone mini-report. The summaries below capture the analyst, scope, key findings, and recommended actions. Full mini-reports are retained in the team's shared evidence repository.

C.1 Email Threat Investigation ([CLICK HERE TO READ](#))

Five inbound emails were analysed: 'Affiliate Marketing Best Practices', 'Code Review Request', 'Download Updated Project Files', 'Important Adobe Update', and 'Team Building Activity'. Indicators were enriched via VirusTotal, URLScan, ANY.RUN, Hybrid Analysis, MX Toolbox, and WHOIS/DigTrace lookups.

Key findings:

- 'Code Review Request' — wtools.io: NJRat-linked credential-harvesting infrastructure; HIGH confidence malicious.
- 'Download Updated Project Files' — contaboserver.net: hosts payload.exe; HIGH confidence malware delivery.
- 'Important Adobe Update' — fake Adobe lure with executable; HIGH confidence malicious.
- 'Team Building Activity' — theannoyingsite.com: social-engineering lure with malicious behaviours.
- 'Affiliate Marketing' — likely benign affiliate spam; flagged for awareness training.

Containment: gateway and proxy blocks applied; recipients notified; IoCs submitted upstream.

C.2 Suspicious Login ([CLICK HERE TO READ](#))

A six-phase investigation methodology was applied: log ingestion, baseline establishment, anomaly detection, threat-intel enrichment, activity correlation, and impact assessment. Authentication logs for Erwin Smith (Financial Analyst) were reviewed across 25–31 July 2023.

Key findings:

- Confirmed account compromise via brute-force from 79.124.60.6 (Bulgaria) following baseline UK activity.
- Confirmed exfiltration of updated_payroll.xlsx and vulnerability_report_June2023.docx.
- Multiple foreign access points: Bulgaria, China, Thailand within hours — credential-stuffing pattern.
- Concurrent legitimate user activity from UK, complicating triage.
- False positive: caffeine.exe (mouse-jiggler) flagged but benign.

Recommended response: immediate password reset and session revocation (completed); MFA enforcement; geo-based Conditional Access; impossible-travel rules; 30-day enhanced monitoring.

C.3 Malware Analysis ([CLICK HERE TO READ](#))

Two samples analysed via static (PE inspection, hashes, signatures) and dynamic (ANY.RUN, Hybrid Analysis sandbox detonation) techniques.

Sample 1 — AsyncRAT (mini_installer):

Open-source .NET RAT; remote command execution and surveillance; injected into svchost.exe.

Sample 2 — Raccoon Stealer (MuiUnattend.exe):

MaaS infostealer; harvests browser-stored credentials, cookies, autofill data and crypto wallets.

Persistence: HKCU\...\CurrentVersion\Run modified; suspected scheduled-task creation (HYPOTHESIS).

C2 infrastructure: 128.24.231.64/65 over HTTPS, mimicking Microsoft endpoints; abuse of login.live.com.

Affected systems: ERP-PROD-002, DATA-PROD-001, DATA-PROD-002, Laptop-01324, -22123, -31214.

C.4 Custom Sentinel Alerts ([CLICK HERE TO READ](#))

Four custom Microsoft Sentinel analytics rules were engineered to convert this sprint's findings into proactive detections (full KQL logic in Appendix E):

- Suspicious Foreign Authentication Attempts — failed→success login progression from non-baseline countries.
- Malware C2 Communication — outbound traffic to known C2 IPs / TLS to suspect domains.
- Exfiltration of Highly Sensitive Data — bulk SharePoint downloads or unusual file-access volumes.
- Malicious Use of Legitimate Microsoft Domains (LotL) — anomalous POSTs to login.live.com / settings-win.data.microsoft.com.

Deployment: rules tested in a non-production workspace prior to production rollout; tuning ongoing.

C.5 Microsoft Patch Tuesday — July 2025 ([CLICK HERE TO READ](#))

132 CVEs were triaged. Six are under active exploitation. Prioritisation framework applied:

- Critical (CVSS 9.0+): patch within 24 hours — CVE-2025-47981 (SPNEGO), CVE-2025-53770 (SharePoint).
- High (CVSS 7.0–8.9): patch within 48–72 hours — CVE-2025-49695 (Office), CVE-2025-47178 (Config Mgr).
- Medium (CVSS 4.0–6.9): patch within 5–7 days — CVE-2025-49719 (SQL Server).

Deployment plan: asset identification → patch testing in isolated lab → phased production rollout (low-risk first) → post-deployment verification with vulnerability re-scan and performance monitoring. Mitigations applied to systems pending patching: WAF rules, network isolation, enhanced logging.

C.6 Mobile Device Vulnerability ([CLICK HERE TO READ](#))

500-device Android fleet assessed. 50% up-to-date, 40% outdated by ~1 year, 10% by ~2 years. Three actively exploited CVEs identified:

- CVE-2021-29256 — Arm Mali GPU UAF; root privilege escalation, no creds required.
- CVE-2023-26083 — Arm Mali GPU memory disclosure; ASLR bypass enabling chained exploits.
- CVE-2023-2136 — Skia/Chrome integer overflow; sandbox escape and RCE via crafted webpage.

Recommendation: mandatory update notice (14-day deadline); restricted-VLAN segmentation for unpatched devices; deploy Microsoft Intune MDM; formalise mobile patching SLAs.

Appendix D — Incident Response Playbook (NIST SP 800-61)

This playbook standardises CyberInfiniti's response to malware-outbreak incidents and the email investigation incident across Microsoft 365 / Azure / Windows environments, defender, 365 and so on. It aligns with NIST SP 800-61 Rev. 2 and the MITRE ATT&CK® Enterprise framework, and is built around the Microsoft security stack.

1. Malware Playbook

Version	Date	Author	Change
1.0	03/07/2025	SOC Analyst Team	Initial draft — playbook development
1.1	03/07/2025	SOC Lead	Peer review and process validation
1.2	03/07/2025	CISO Office	Approved for distribution

D.1 Lifecycle Overview

Prepare	Detect	Analyse	Contain	Eradicate	Recover	Post-Incident
Readiness, tooling, training	Identify & validate alerts	Triage, scope, root cause	Stop spread; isolate	Remove malware & vectors	Restore & harden	Lessons learned & improvement

D.2 Microsoft Security Stack

Tool	Purpose	Phases
Microsoft Defender for Endpoint	EDR — detection, isolation, forensics	Detect / Contain / Eradicate
Microsoft Sentinel (SIEM)	Log aggregation, correlation, SOAR playbooks	Detect / Analyse / Post-Incident
Defender for Office 365	Email & collaboration threat protection	Detect / Contain
Azure AD (Entra ID)	Identity protection, Conditional Access, MFA	Prepare / Contain / Recover
Defender for Cloud	Cloud workload protection & vulnerability mgmt	Prepare / Detect
Microsoft Intune	Endpoint management, compliance, remote wipe	Contain / Eradicate / Recover
Azure Firewall / NSGs	Network segmentation & traffic filtering	Contain / Eradicate
VirusTotal / ANY.RUN	Malware analysis & sandbox detonation	Analyse

D.3 Phase Detail (Compact)

Phase 1 — Prepare

Establish readiness to detect and respond effectively.

- Define core SOC team (SOC Lead = Incident Commander; L1/L2 Analysts; Threat Intel Analyst).
- Define extended team (CISO, IT Infra Manager, Legal/PR/Compliance).

- Document escalation paths: Internal — SOC → SOC Lead → CISO → Exec Board; External — Client → Regulators → Law Enforcement → ISACs.
- Deploy & configure Defender for Endpoint on all managed hosts.
- Configure Sentinel analytic rules and SOAR playbooks; integrate IoC feeds.
- Quarterly tabletop exercises and IR drill simulations.

Phase 2 — Detect

Identify and validate malware incidents rapidly.

- Sources: Defender for Endpoint EDR alerts; Sentinel correlation; Defender for O365; user reports.
- Indicators: unexpected services at boot; unusual outbound traffic; AV tampering; svchost injection; Run-key changes; CPU/memory spikes.
- Risk factors: PII at risk; credential theft confirmed; lateral movement; VVIP accounts at risk.
- Initial response: create Sentinel incident with severity; pull NSG flow logs; initiate Defender scans.

Phase 3 — Analyse

Determine scope, impact, and root cause.

- Severity assessment: Critical / High / Medium / Low based on asset value, data sensitivity and blast radius.
- Classification: RAT, Infostealer, Ransomware, Worm, Cryptominer, Dropper — identify family and variant.
- Static analysis: extract MD5/SHA-256; query VirusTotal; check Sentinel TI for IoC matches.
- Dynamic analysis: detonate in ANY.RUN / Defender sandbox; capture process, registry, file, and network changes.
- Threat intel: map to MITRE ATT&CK; cross-reference feeds; attribute to known clusters where possible.
- Outputs: confirmed IoCs; attack-chain reconstruction; affected systems inventory; analyst report.

Phase 4 — Contain

Stop the spread of malware and prevent further damage.

- Short-term (0–4 hrs): Defender for Endpoint device isolation; block C2 IPs at Azure Firewall/NSGs; disable compromised AAD accounts; quarantine files; sinkhole malicious domains.
- Long-term (4–24 hrs): VLAN segmentation of affected segments; Conditional Access restrictions; enhanced Sentinel audit logging; Defender custom indicator policies for hashes; client-account-manager notification per MSSP SLA.
- Decision gate: confirm containment effective across all assets before proceeding.

Phase 5 — Eradicate

Remove all traces of malware and close attack vectors.

- Confirm samples in Defender sandbox; terminate identified PIDs; disable compromised services and scheduled tasks.
- Delete malware from %TEMP% and AppData directories; revert unauthorised registry modifications.
- Adjust Azure Firewall to block IoCs; update Sentinel analytic rules.
- Run full AV scan with updated definitions; capture volatile memory before remediation.
- Communicate via encrypted channel; update Sentinel ticket; brief SOC Lead and CISO; document forensic timeline.

Phase 6 — Recover

Restore systems to normal operations and strengthen defences.

- Re-image affected systems from known-clean backups; update IDS/IPS signatures; reconnect only after CISO sign-off.
- Force global password reset (priority: VVIP and admin); enforce MFA via Conditional Access; rotate certificates and API keys.

- Apply outstanding patches via Intune; harden baselines; deploy SOAR automations to short-circuit similar future events.

Phase 7 — Post-Incident

Capture lessons and continuously improve.

- Within 14 days of closure: formal post-incident review with all stakeholders; documented action items with owners.
- Update playbooks, detection rules and IoC lists; share sanitised learnings across the team.
- Run a purple-team exercise simulating the observed attack chain to validate detection and response improvements.

Critical reminder — Memory forensics: capture volatile memory from affected systems before remediation to identify in-memory-only malware components. Use Defender for Endpoint Live Response for remote acquisition.

CYBERINFINTI

SECURITY OPERATIONS

EMAIL INVESTIGATION
& ANALYSIS PLAYBOOK

Phishing • Credential Harvesting • Malware Delivery

Microsoft 365 / Exchange Online Environment

Document Type	Incident Response Playbook
Classification	Internal — Security Operations
Version	1.1
Prepared by	CyberInfiniti SOC Team

1. Executive Summary

This playbook documents the Email Investigation and Analysis programme operated by the CyberInfiniti Security Operations Centre (SOC) for users of the Microsoft 365 / Exchange Online environment. It defines the end-to-end response lifecycle for suspicious or malicious emails, from user reports through triage, containment, eradication, recovery and lessons learned.

During the most recent operations sprint, five (5) reported email threats were investigated. Analysis revealed a mix of benign, suspicious and clearly malicious messages employing impersonation of trusted brands (Adobe, internal teams), abuse of legitimate cloud infrastructure (Gmail relays, Google Drive), credential-harvesting URLs, and direct delivery of executable payloads.

Sprint Snapshot — 5 Emails Analysed

- 1 Benign / Unsolicited: Affiliate Marketing Best Practices
- 1 Suspicious: Team Building Activity (theannoyingsite.com)
- 3 Malicious: Code Review Request, Download Updated Project Files, Important Adobe Update
- Primary techniques: brand impersonation, display-name spoof, malicious URL, .exe payload delivery

2. Scope & Objectives

This playbook applies to all email reported to the SOC via the Microsoft Outlook Report Phishing add-in, the abuse mailbox, automated alerts from Microsoft Defender for Office 365, and escalations from the IT Service Desk.

Objectives

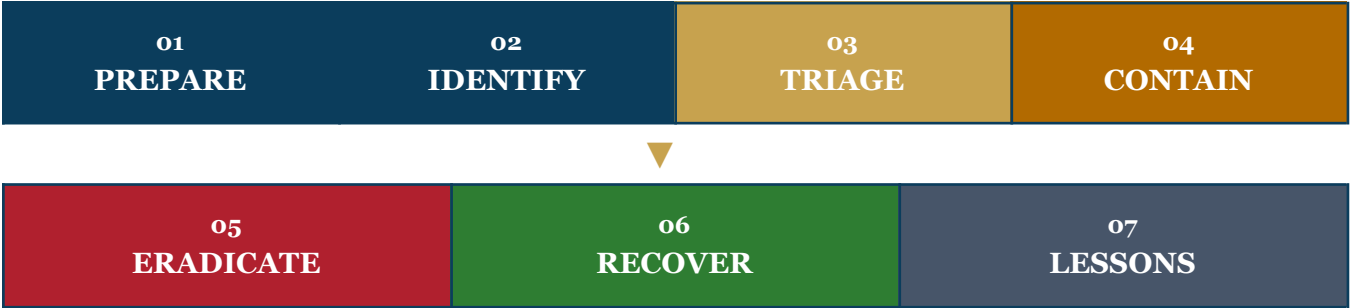
- Provide a repeatable, evidence-driven workflow for triaging reported email.
- Reduce mean time to contain (MTTC) malicious email below 60 minutes.
- Eliminate the threat from all affected mailboxes and prevent re-delivery.
- Capture indicators of compromise (IOCs) and feed them to detection controls.
- Drive measurable improvement in user reporting quality and resilience.

3. Roles & Responsibilities

Role	Responsibility
End User	Reports suspicious email via the Outlook Report Phishing button or abuse@company.com without forwarding, replying or clicking embedded content.
Service Desk (Tier 1)	Acknowledges report, confirms scope (single user vs. campaign), opens ticket, hands off to SOC.
SOC Analyst (Tier 2)	Owns the investigation: header analysis, URL/attachment detonation, IOC enrichment, verdict determination.
SOC Lead / Incident Manager	Authorises containment actions (mailbox purge, sender/domain block, account lockdown). Owns communication.
Threat Intel	Enriches IOCs against external feeds, correlates with prior campaigns, publishes a threat advisory.
IT Operations	Applies blocks at the email gateway, web proxy and DNS. Resets credentials and rebuilds compromised endpoints when required.
Communications / HR	Coordinates user-facing communication and any disciplinary or training follow-up.

4. Incident Response Lifecycle

The CyberInfiniti email-investigation lifecycle aligns with NIST SP 800-61r2 and is tuned for a Microsoft 365 environment. Each phase has explicit entry criteria, owner, key actions and exit criteria.



Guiding Principle

Every reported email is treated as suspicious until proven otherwise. Verdicts are evidence-driven (headers, reputation, sandbox behaviour) — never based on subject line, display name or user opinion alone.

Preparation ensures the SOC, technology stack and end users are positioned to detect and respond to email-borne threats before an incident occurs.

Technology Readiness

- Microsoft Defender for Office 365 (MDO) — Safe Links, Safe Attachments, anti-phish and anti-spam policies tuned and enforced.
- Exchange Online Protection (EOP) — connection filtering, transport rules, DKIM signing for owned domains, DMARC at p=quarantine or p=reject.
- Microsoft Sentinel — ingestion of Office 365, AAD Sign-In, and Defender alerts for correlation.
- Tenant Allow/Block Lists (TABL) configured for senders, domains, URLs and file hashes.
- Outlook Report Phishing add-in deployed to all mailboxes; submissions routed to Microsoft and the SOC.

Process Readiness

- Documented playbook, runbooks and decision trees stored in the SOC knowledge base.
- Defined service levels: acknowledge ≤ 15 min, triage ≤ 60 min, contain ≤ 4 h for confirmed malicious.
- Quarterly tabletop exercises against realistic phishing scenarios.

People Readiness

- Mandatory phishing-awareness training on hire and annually.
- Quarterly simulated phishing campaigns with targeted remediation training.
- Clear, blame-free reporting culture — users are recognised for reporting, including false positives.

PHASE 2 IDENTIFY (DETECTION & REPORTING)

Detection sources for reported and auto-discovered email threats.

Source	Description
User Report (Outlook add-in)	Primary channel. Submission lands in the SOC review queue and is co-submitted to Microsoft.
Abuse Mailbox	abuse@company.com — fallback when the add-in is unavailable. Auto-parsed by SOAR.
MDO Alerts	Zero-hour Auto Purge (ZAP), high-confidence phishing, malware detonation, impersonation alerts.
Sentinel Analytics	Cross-source correlation: suspicious sign-in following email click, mass-delete rules, anomalous forwarding.
Threat Intel Feed	External IOCs matched against historical mail flow via threat-hunting queries.

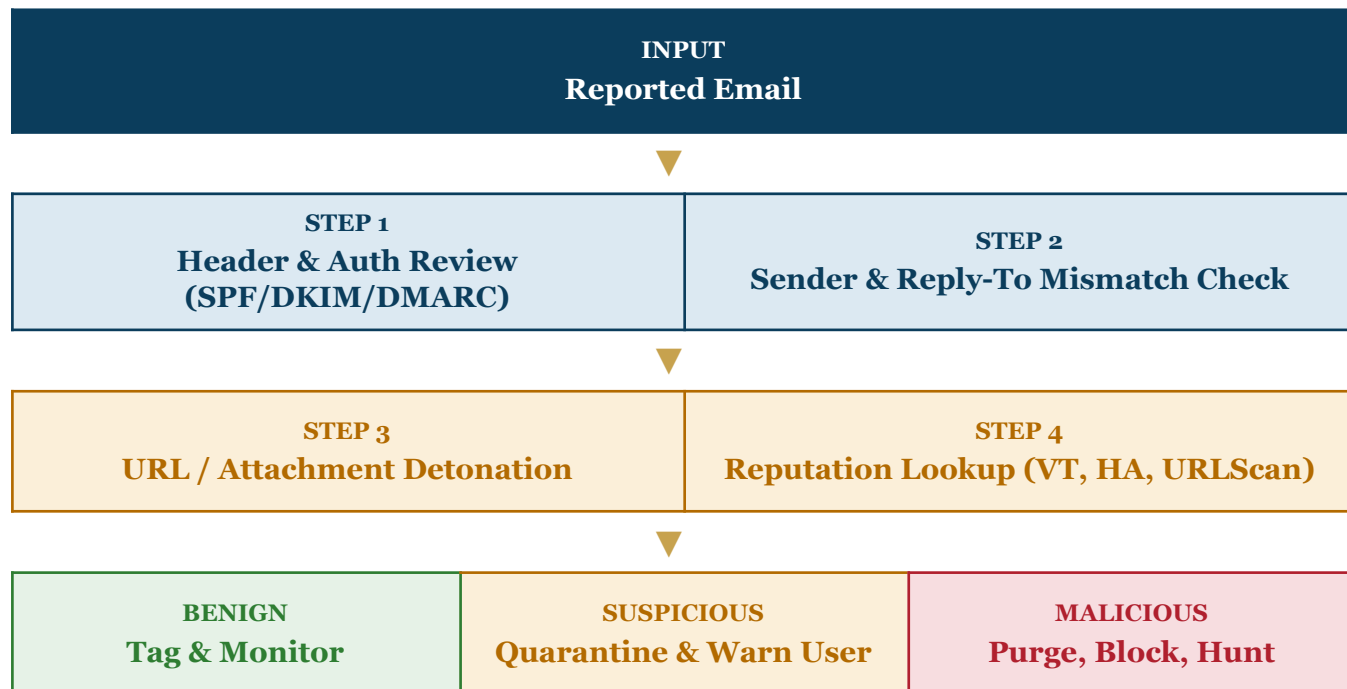
What the Analyst Captures at Intake

Reporter, recipient(s), subject, sending address, sending IP, reply-to, full headers, original .eml, all URLs, attachment hashes, time of receipt and time of report.

PHASE 3 TRIAGE & ANALYSIS

Triage determines verdict (Benign / Suspicious / Malicious) using a deterministic, evidence-driven workflow.

Triage Decision Flow



Triage Severity Matrix

Severity	Indicators	Examples (this report)	Initial Action
Low (Benign)	Auth pass, clean reputation, unsolicited only	Affiliate Marketing email	Tag, monitor, user awareness
Medium (Suspicious)	Display-name spoof, abusive link, weak context	Team Building Activity (theannoyingsite.com)	Quarantine, warn user, block URL
High (Malicious)	Credential harvester, payload (.exe), VT detections	Code Review Request, Adobe Update, Project Files	Purge from mailboxes, block sender + domain, EDR sweep

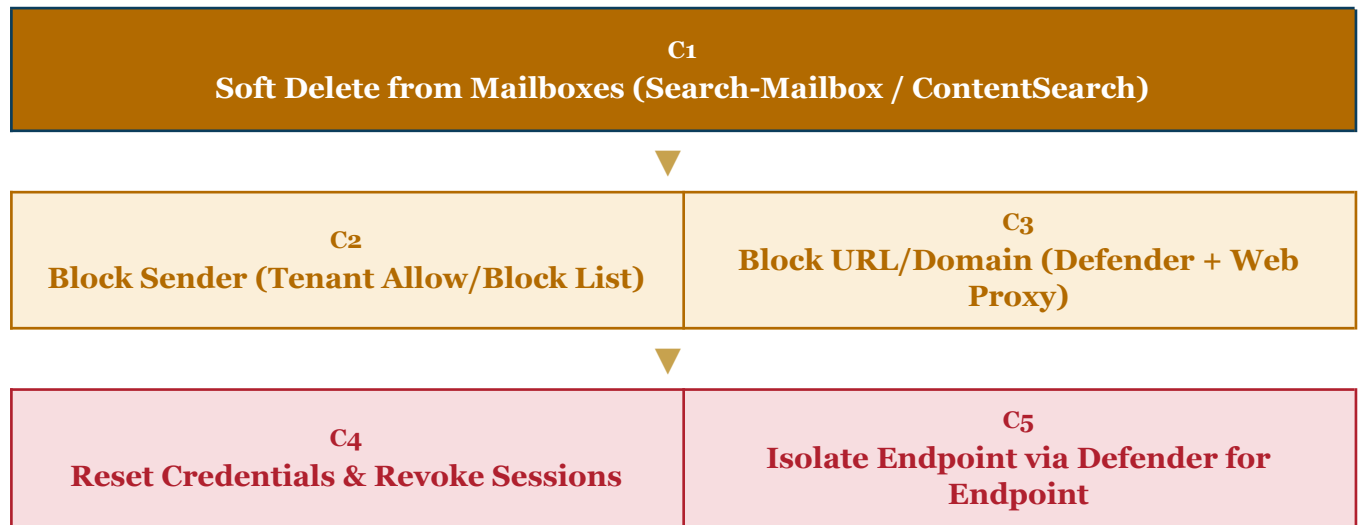
Header Authentication — What to Check

- SPF — does the sending IP match the From-domain's SPF record?
- DKIM — is the signature valid and aligned with the From-domain?
- DMARC — does the message align (SPF or DKIM) with the From-domain and meet the policy?
- Reply-To vs From — mismatched reply-to is a classic phishing tell.

- Display Name vs Address — friendly name impersonating a brand while sending from a free webmail relay (e.g. Gmail) is a high-confidence indicator.

PHASE 4 CONTAINMENT

Containment removes the threat from the environment and prevents further exposure while the full investigation continues.



Microsoft 365 Containment Actions

- Soft-delete the message from all recipient mailboxes via Microsoft Purview Content Search → Purge (SoftDelete).
- Add sender address and root domain to the Tenant Allow/Block List (TABL).
- Submit URL and root domain to Defender Safe Links and the corporate web proxy block list.
- Submit attachment hash to Defender for Endpoint custom indicators (Block & Remediate).
- If a user clicked / entered credentials: revoke all active sessions in Entra ID, force password reset, enforce re-MFA, audit mailbox forwarding rules and OAuth grants.
- If a payload executed: isolate device via Defender for Endpoint, collect investigation package, escalate to malware-outbreak playbook.

Eradication removes all traces of the threat and underlying weaknesses that allowed delivery.

- Confirm message removal across every recipient mailbox (including Recoverable Items / Purges folder where licensing permits).
- Hunt across mail flow for the same sender, subject, URL, attachment hash and SHA256 over the prior 30 days using Threat Explorer and Advanced Hunting (KQL).
- Hunt across endpoints for execution of the payload, child processes and outbound network connections to the C2.
- Hunt across identity for sign-ins originating from suspicious IPs/ASNs following the click time.
- Strengthen detections: convert observed IOCs into Sentinel analytic rules and TABL entries; tune anti-phish impersonation policy if a brand spoof was used.

Sample KQL Hunt — URL Click Telemetry

UrlClickEvents

| where Timestamp > ago(30d)

| where Url has_any ("wtools.io", "theannoyingsite.com", "contaboserver.net")

| project Timestamp, AccountUpn, Url, ActionType, IPAddress, ThreatTypes

PHASE 6 RECOVERY

Recovery restores affected users and systems to a known-good, monitored state.

- Restore mailbox access and confirm no malicious inbox rules, forwarders or delegates remain.
- Re-enable user accounts after credential reset, MFA re-enrolment and conditional-access review.
- Return rebuilt or remediated endpoints to production after EDR clean-bill-of-health.
- Communicate resolution to the reporting user and (where appropriate) line manager.
- Apply a 14-day heightened-monitoring window for affected accounts and devices.

PHASE 7 LESSONS LEARNED

Continuous improvement closes the loop. A lessons-learned review is conducted within 5 business days of every confirmed malicious incident.

- Root cause: how was the message delivered, why was it not caught, and what allowed any subsequent compromise?
- Detection gap: what new analytic rule, TABL entry, transport rule or policy will catch the next variant?
- User behaviour: were the right users targeted? Do they need additional training or a focused simulation?
- Process: did the SLA hold? Where was time lost? Update the runbook and decision tree accordingly.
- Metrics: feed MTDD, MTTR, click-rate and report-rate into the monthly SOC scorecard.

12. Investigation Case Studies

The five case studies below are drawn from the most recent operations sprint and demonstrate the playbook applied end-to-end. Each case follows the same structure: artefacts collected, content overview, behavioural analysis, indicators observed and verdict.

Case 1: Affiliate Marketing Best Practices

Email Description and Artifacts Collected

Sending Address	jasonconrado99@gmail.com
Subject Line	Affiliate Marketing Best Practices
Recipient	kendrick.lawal@company.com
Sender IP	209.85.216.49
Reverse DNS	mail-pj1-f49.google.com
Reply-To	jasonconrado99@gmail.com
Date / Time	Sat, 29 Jul 2023 15:46:13 +0100
Full URL	https://www.authorityhacker.com/successful-affiliate-websites-examples/?referral_code=aef49w31123
Root Domain / IP	authorityhacker.com / 104.26.15.11

Content Overview

Sent from a Gmail account, the email shares an article about affiliate marketing and invites the recipient to visit an external website via a link containing a referral code. It is presented as a helpful resource from a peer.

Behavioural Analysis

The message uses a legitimate-looking business topic and a friendly tone to encourage link clicking. The presence of a referral parameter suggests affiliate-tracking intent rather than direct exploitation.

Key Indicators Observed

- SPF, DKIM and DMARC all PASS — message is properly authenticated.
- VirusTotal: 0/95 detections on URL and root domain.
- URL2PNG and ANY.RUN render the destination as a genuine homepage with no fake login or payload.
- Hybrid Analysis returns no specific threat.
- Reverse DNS on 209.85.216.49 confirms origin from mail-pj1-f49.google.com (legitimate Google relay).

VERDICT: NON-MALICIOUS — Likely benign / unsolicited — treat with caution; not a trusted internal communication.

Case 2: Code Review Request

Email Description and Artifacts Collected

Sending Address	zelatcol@gmail.com
Subject Line	Code Review Request
Recipient	michelle.jackson@company.com
Sending Server IP	209.85.214.178
Reverse DNS	mail-pl1-f178.google.com
Reply-To	zelatcol@gmail.com
Date / Time	Sat, 29 Jul 2023 15:22:06 +0100
Full URL	https://wtools.io/paste-code/bOs4
Root Domain / IP	wtools.io / 188.166.15.204

Content Overview

A targeted social-engineering attempt that uses a fake code-review request to lure a developer into pasting source code into an attacker-controlled site, exposing both code and any embedded secrets.

Behavioural Analysis

Although headers authenticate cleanly via Gmail relay, the embedded URL has a confirmed malicious reputation and is associated with NJRat malware activity. The lure is industry-specific and credible to a software engineer.

Key Indicators Observed

- VirusTotal: 13/95 vendors flag the URL as malicious; links to NJRat infrastructure.
- WHOIS: domain registered ~2 years ago via Namecheap with no public registrant detail.
- ANY.RUN: destination returns 404 — likely taken offline after malicious use.
- URL2PNG: snapshot confirms a fake code-review portal designed to harvest pasted source.
- Hybrid Analysis and urlscan.io both flag the site as malicious.

VERDICT: MALICIOUS — Malicious — credential / code harvester. Block sender, purge from mailboxes, hunt for clicks.

Case 3: Download Updated Project Files

Email Description and Artifacts Collected

Sending Address	projectdept@kanzalshamsprojectmgt.com
Subject Line	Download Updated Project Files
Recipient	nikefury@company.com
Sending Server IP	209.85.216.41
Reverse DNS	mail-pj1-f41.google.com
Reply-To	projectdept@kanzalshamsprojectmgt.com
Date / Time	Sat, 29 Jul 2023 15:37:34 +0100
Full URL	https://drive.google.com/uc?export=download&id=1bstuGMLer-fbJbcGG5JiqnleKTSKvq5y

Content Overview

Posing as a Project Management Office, the email claims that requested project files are ready and provides a direct download link hosted on Google Drive — abusing trusted cloud infrastructure to bypass URL reputation controls.

Behavioural Analysis

Task-oriented language creates urgency and legitimacy. The use of a generic Gmail relay combined with a Google Drive download link is a recognised pattern for malware delivery and credential harvesting.

Key Indicators Observed

- SPF / DKIM / DMARC PASS but display-name vs. sender domain mismatch.
- Sending domain (kanzalshamsprojectmgt.com) inconsistent with relay (Gmail) — classic spoofing posture.
- Drive object flagged on VirusTotal; root domain known abused for malware staging.
- Hostname check via WhatIsMyIPAddress confirms generic Google relay path.
- No prior business relationship with the sending entity — unsolicited.

VERDICT: MALICIOUS — High-risk — likely phishing / malware delivery via Google Drive. Do not interact outside the sandbox.

Case 4: Important Adobe Update

Email Description and Artifacts Collected

Sending Address	alfredegov@gmail.com
Subject Line	Important Adobe Update
Recipient	lily.tunechy@company.com
Sending Server IP	209.85.215.170
Reverse DNS	mail-pj1-f41.google.com
Reply-To	alfredegov@gmail.com
Date / Time	Sat, 29 Jul 2023 15:54:42 +0100
Full URL	http://vmi1159541.contaboserver.net/payload.exe
Root Domain / IP	vmi1159541.contaboserver.net / 209.145.51.44

Content Overview

Brand-impersonation attack from a Gmail account posing as the Adobe Support Team. Claims an urgent software update is required and links to a downloadable .exe payload hosted on a non-trusted server.

Behavioural Analysis

Uses urgency and authority (security update) to pressure the user into executing the payload. The displayed link suggests an Adobe update while the actual href points to an unrelated hosting domain — classic deceptive-link technique.

Key Indicators Observed

- SPF / DKIM / DMARC PASS but sender impersonates Adobe from a Gmail address.
- Spam Confidence Level (SCL): 5 — elevated.
- Direct link to an .exe file on vmi1159541.contaboserver.net — VirusTotal: malicious.
- WHOIS: domain registered 2017-03-05 via RegistryGate GmbH.
- URL2PNG: destination served credential-harvesting content prior to takedown.

VERDICT: MALICIOUS — Malicious — brand impersonation + executable payload. Treat as highly dangerous.

Case 5: Team Building Activity

Email Description and Artifacts Collected

Sending Address	alfredegov@gmail.com
Subject Line	Team Building Activity
Recipient	shina.kagawa@company.com
Sending Server IP	209.85.210.182
Reverse DNS	mail-pf1-f182.google.com
Reply-To	alfredegov@gmail.com
Date / Time	Sat, 29 Jul 2023 16:27:56 +0100
Full URL	http://theannoyingsite.com/
Root Domain / IP	theannoyingsite.com / 209.145.51.44

Content Overview

A casual-toned message posing as a colleague invites the recipient to visit theannoyingsite.com under the guise of a fun team-building activity. There is no business context and no personalisation.

Behavioural Analysis

Low-sophistication social-engineering lure designed to nudge users toward a non-business external site that aggressively abuses browser features (clipboard access, drive-by downloads, fake logout endpoints, popup spam).

Key Indicators Observed

- External Gmail sender; same address used in the Adobe Update case (campaign linkage).
- VirusTotal: 13/95 vendors flag the destination.
- ANY.RUN: clipboard access, attempted drive-by download (cat-marshmallows.jpg), fake logout endpoints, popup spam.
- WHOIS: domain registered ~9 years ago via Namecheap.
- URL2PNG: hosts a fake login portal at landing.

VERDICT: SUSPICIOUS — Suspicious / phishing-adjacent — quarantine, warn user, block at proxy.

13. Indicators of Compromise (IOCs)

Consolidated IOCs from this sprint. Push to TABL, web proxy, EDR custom indicators and Sentinel watchlists.

Type	Indicator	Notes
Sender Address	zelatcol@gmail.com	Code Review Request — malicious
Sender Address	projectdept@kanzalshamsprojectmgt.com	Project Files lure — malicious
Sender Address	alfredegov@gmail.com	Adobe Update + Team Building — malicious / suspicious
URL	https://wtools.io/paste-code/bOs4	Code/credential harvester (NJRat)
URL	http://vmi1159541.contaboserver.net/payload.exe	.exe payload — Adobe impersonation
URL	http://theannoyingsite.com/	Abusive site — drive-by behaviour
URL	https://drive.google.com/uc?export=download&id=1bstuGMLer-fbJbcGG5JiqnleKTSKvq5y	Drive-hosted payload
Domain	wtools.io	Block at web proxy and Safe Links
Domain	vmi1159541.contaboserver.net	Block at web proxy and Safe Links
Domain	theannoyingsite.com	Block at web proxy and Safe Links
IP	188.166.15.204	wtools.io
IP	209.145.51.44	Contaboserver / theannoyingsite shared host

14. Microsoft 365 Response Reference

Operational reference for the most common containment and eradication actions in a Microsoft 365 / Exchange Online tenant.

Tenant Allow/Block List (TABL)

- Microsoft 365 Defender → Policies & Rules → Threat policies → Tenant Allow/Block Lists.
- Add entries for Senders, Domains, URLs and File Hashes with an expiry and a justification note.

Purging Mail from Mailboxes

- Microsoft Purview → Content Search → build a query (sender, subject, date) → Preview → Purge → SoftDelete.
- For high-volume incidents, use New-ComplianceSearchAction -Purge -PurgeType SoftDelete via Security & Compliance PowerShell.

Defender for Office 365 — Threat Explorer

- Use Threat Explorer to confirm delivery scope, view URL clicks, and submit messages to Microsoft for analysis.
- Trigger AIR (Automated Investigation & Response) to validate hunts and queue remediation.

Identity Containment (Entra ID)

- Revoke all refresh tokens (Revoke-AzureADUserAllRefreshToken / Revoke-MgUserSignInSession).
- Force password reset, require re-MFA, review and remove rogue OAuth consents.
- Audit mailbox rules (Get-InboxRule) and remove suspicious forwarders.

Endpoint Containment (Defender for Endpoint)

- Isolate device, collect investigation package, run live response, push custom indicator (hash/URL/IP).

15. Appendix — Tools & References

Investigation & Enrichment Tools

- VirusTotal — URL, domain, IP, file hash reputation.
- Hybrid Analysis — automated sandbox detonation.
- ANY.RUN — interactive sandbox for URL and file analysis.
- URL2PNG — safe rendering of suspicious URLs.
- urlscan.io — URL scanning and historical data.
- MxToolbox — DNS, reverse DNS, blacklist and SPF/DMARC checks.
- DigTrace / WannaBrowser — DNS query inspection and HTTP request emulation.
- Microsoft 365 Defender, Threat Explorer, Advanced Hunting (KQL).
- Microsoft Sentinel — SIEM correlation and analytics.

References

- NIST SP 800-61r2 — Computer Security Incident Handling Guide.
- MITRE ATT&CK — Initial Access (T1566 Phishing) and sub-techniques.
- Microsoft Defender for Office 365 documentation.
- CISA — Phishing Guidance for End Users and Organisations.

Document Control

Owner: CyberInfiniti SOC. Review cadence: every 6 months or after any major incident.
Distribution: SOC, IT Operations, Service Desk, Compliance. Classification: Internal.

Appendix E — Custom Sentinel Detection Rules

Four custom Microsoft Sentinel analytics rules were engineered during the sprint to convert the observed attack patterns into proactive future detections. Each rule is summarised below with logic intent, data sources, and severity. Full KQL is maintained in the SOC Sentinel workspace under the rule pack ‘CYBI-SOC-2026-Q2’.

E.1 Suspicious Foreign Authentication Attempts

Severity	Data Sources	Detection Logic
MEDIUM	SigninLogs (Azure AD)	Identifies failed→success authentication progressions where the successful login originates from a country not present in the user's 30-day baseline. Mirrors the pattern observed in the account-compromise incident (failed logins from BG/CN/TH followed by success from BG).

E.2 Malware Command & Control (C2) Communication

Severity	Data Sources	Detection Logic
HIGH	DeviceNetworkEvents (MDE), Firewall logs	Triggers on outbound TLS or HTTP communication to known C2 IPs (128.24.231.64/65) or new domains exhibiting beaconing characteristics (small, regular, periodic POSTs). Aligns with the AsyncRAT / Raccoon Stealer C2 profile.

E.3 Exfiltration of Highly Sensitive Data

Severity	Data Sources	Detection Logic
----------	--------------	-----------------

HIGH	OfficeActivity (SharePoint), DLP logs	Detects bulk file downloads from sensitivity-labelled SharePoint sites within a short window (default ≥ 10 files / 5 minutes), or any download of files matching the regex pattern 'payroll vulnerability salary ssn'. Mirrors the data-exfiltration step of the account-compromise incident.
------	---------------------------------------	--

E.4 Malicious Use of Legitimate Microsoft Domains (LotL)

Severity	Data Sources	Detection Logic
HIGH	DeviceNetworkEvents (MDE)	Flags anomalous HTTP POSTs or large outbound transfers to login.live.com or settings-win.data.microsoft.com from non-browser processes, or from devices not previously observed communicating with these endpoints. Catches the Living-off-the-Land tunnelling technique used by Raccoon Stealer.

E.5 Deployment Methodology

- Develop & test in a non-production Sentinel workspace using historical incident data.
- Tune for false-positive reduction over a 7-day observation window.
- Promote to production via Azure DevOps pipeline (analytics-rules-as-code).
- Couple high-severity rules with SOAR playbooks (Azure Logic Apps) for automated containment actions: endpoint isolation, session revocation, account disablement.
- Quarterly review and re-tuning aligned with the threat-intelligence feed refresh cycle.

— End of report —